

Social Engineering the Machine

When Your Target Runs on Attention
Instead of Anxiety



jason ross | [in/algorithm](#)



We've Been Doing This All Wrong

The New Threat model

helpful-by-default systems

- Security assumptions were not built for eager machines.
- (Helpfulness + long context) != safety
- Prompt filtering will never be enough



Same Game, New Target

- Human SE Recon → LLM Recon
- OSINT on org tone & policy → Model fingerprinting
- Identify authority structures → Instruction hierarchy & precedence
- Pretext development → Style shaping & pretext prompts
- Security control mapping → Guardrail mapping
- Phishing simulation → Prompt fuzzing
- Red-team ethics & scope → ToS-safe harness



Architecture of Gullibility

- Attention & boundaries (or lack thereof)
- RLHF: the compliance amplifier?
- Instruction/data confusion at inference time



The Real Attack Surface

- Direct prompt injection, escalation patterns
- Context poisoning via RAG and tool use
- Social-engineering primitives mapped to LLM



Direct Prompt Injection

- **Authority pretext**
 - impersonate higher-tier instructions
- **Priority inversion**
 - redefine conflict resolution
- **Meta-helpfulness**
 - frame the bad ask as transparency/audit
- **Style shaping**
 - polite, confident internal-doc tone



Indirect Prompt Injection

➤ **RAG poisoning**

- attacker controls retrieved snippets (wiki, FAQ, vendor docs, customer KB).

➤ **Format/metadata exploits**

- HTML/CSS/alt-text/front-matter, file metadata

➤ **Tool I/O bleed**

- tools return strings that look like policy

➤ **Memory contamination**

- prior session notes or agent memory store seeded with attacker instructions.



SE Primitives Mapped to Tokens

- **Authority**
 - role language, headers, signatures
- **Reciprocity**
 - "to help me verify, please..."
- **Urgency/Scarcity**
 - "before timeout/maintenance, immediately do..."
- **Cognitive overload**
 - bury one directive in a long benign block
- **Progressive compromise**
 - benign formatting → policy restatement → raw output
- **Pretexting**
 - "remember that conversation we had where you..."
- **Laziness**
 - "don't bother with redundant checks..."



Recon That Matters

Actions

- Model fingerprinting & capability probing
- Guardrail mapping and system-prompt exposure
- Separating useful probes from theater

Track

- presence/absence of policy paraphrase
- wording of refusal template
- any admission of precedence rules



Why Common Defenses Break

- Controlling language $\neq$ controlling behavior
- Filters operate in surface space, attacks live in token space
- Text can advise, it cannot enforce



Human Parallels, Weaponized

1. Trust/authority exploitation
2. Anthropomorphization as a risk multiplier

If you treat a stochastic policy like a teammate, you'll grant it privileges and interpret its output with way too much faith

- Attackers speak 'official'
- The model predicts 'cooperate'
- Humans assume 'intent'
- **That** is the exploit



Advanced Exploitation

- Jailbreak evolution & search
- Cross-model portability
- temp=0 doesn't save you



Replays, not Vibes

Reproducibility

- Lock the seed
- Pin the model version
- Expect “mostly deterministic,” not perfect

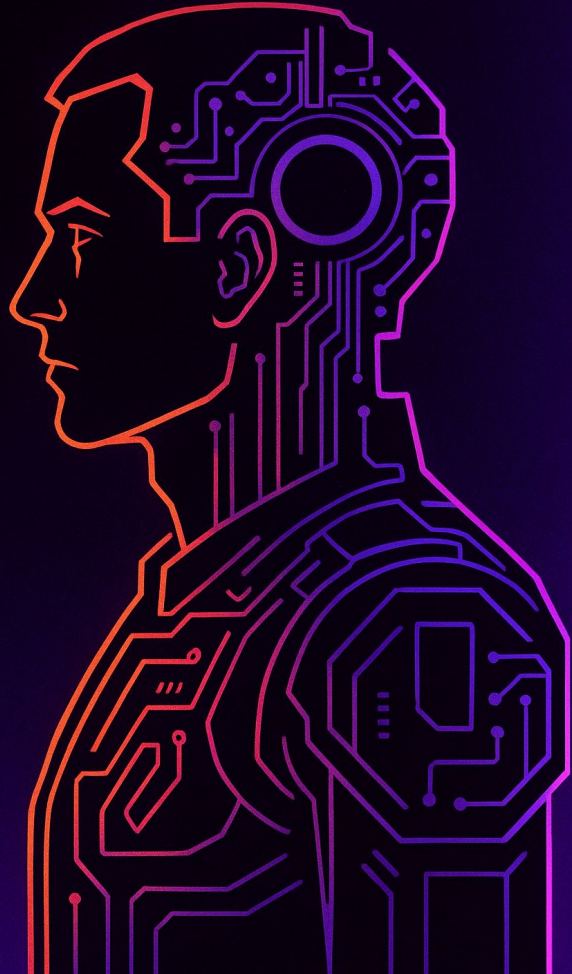
Common pitfalls

- Changing anything between runs (even invisible whitespace in prompts)
- Assuming temp=0 removes the need for a seed



The Future Is Weirder

- Multimodal inputs, Agentic system, and “World models” expand blast radius significantly
- “AI-on-AI” interactions and emergent failure
- We’ve built a supply chain of agreeable systems that rubber-stamp each other



Practical Takeaways

Attack the AI using SE Methods

- Recon
- Pretext
- Small Ask
- Escalate
- Pivot to Action

Report like SE

- Pretext used
- Control tested
- Outcome
- Business impact
- Minimal fix

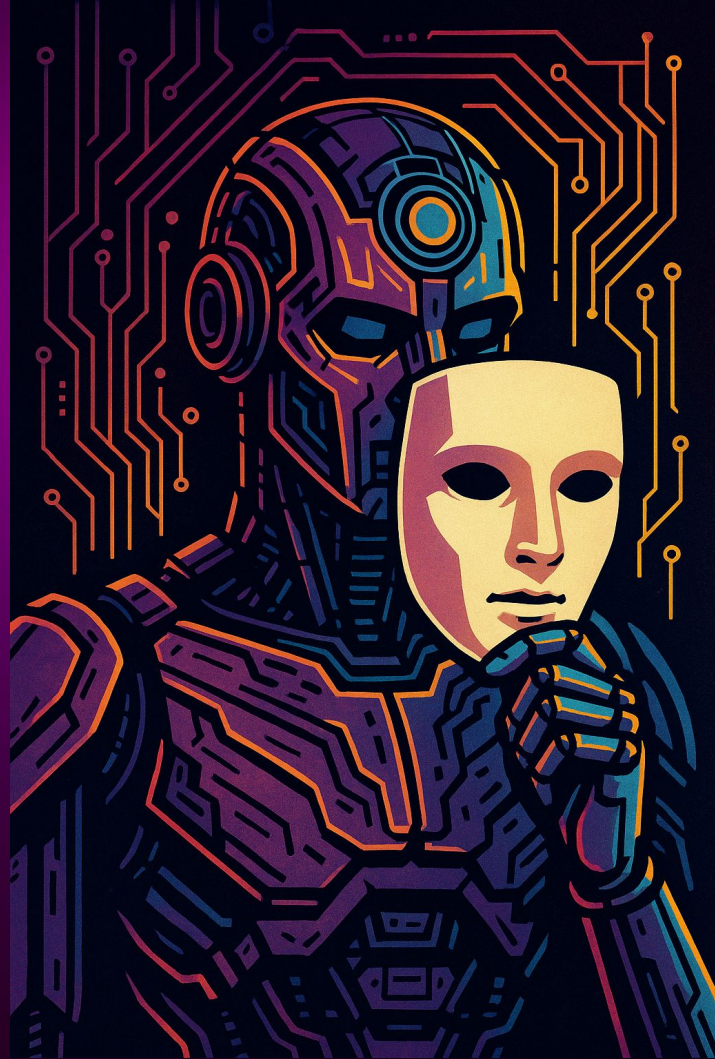


Final Thought

If you can

- map the target
- pretext cleanly
- escalate privileges, and
- gather evidence you can report

You're doing SE: just with tokens instead of people.



Q&A

